

PROTOCOLO DE SEGURIDAD DE LA INFORMACIÓN Y TRABAJO REMOTO (WNH)

NovaTech Solutions Versión: 2025.1 (Comprehensive) Departamento: InfoSec & IT Operations

Clasificación: Uso Interno - Confidencial Alcance: Obligatorio para todos los empleados y contratistas.

1. INTRODUCCIÓN: LA SEGURIDAD COMO RESPONSABILIDAD COMPARTIDA

En un entorno "Remote-First", el perímetro de seguridad de NovaTech no son las paredes de una oficina, sino cada uno de los dispositivos desde los que operan nuestros empleados. Ya no defendemos un castillo; defendemos una flota dispersa por todo el mundo.

Nuestra filosofía es "Zero Trust" (Confianza Cero):

Nunca confiar, siempre verificar: No asumimos que una conexión es segura solo porque viene de un dispositivo conocido.

Menor Privilegio Posible: Solo tendrás acceso a los datos estrictamente necesarios para tu rol.

Asumir la Brecha: Operamos pensando que el riesgo de ataque es inminente, lo que nos obliga a estar siempre vigilantes.

El incumplimiento de estos protocolos no es un error administrativo; es una falta grave que pone en riesgo la propiedad intelectual de la empresa, los datos de nuestros clientes y la viabilidad del negocio.

2. GESTIÓN Y SEGURIDAD DE DISPOSITIVOS (ENDPOINTS)

Tu laptop es la puerta de entrada a NovaTech. Debe ser tratada como una bóveda.

2.1 Uso Exclusivo del Hardware Corporativo

Regla de Oro: El equipo provisto por NovaTech es para uso exclusivamente profesional.

Prohibiciones Explícitas:

No se permite prestar el equipo a familiares (cónyuges, hijos) para tareas escolares, navegación personal o juegos. Un clic accidental de un niño puede descargar malware.

No se permite instalar software personal no autorizado (juegos crackeados, clientes de torrents, herramientas de minería de criptomonedas).

BYOD (Bring Your Own Device): El uso de computadoras personales para acceder a sistemas críticos de NovaTech está prohibido, salvo autorización escrita del CISO y previa instalación de nuestro agente de MDM (Mobile Device Management).

2.2 Cifrado de Disco (Full Disk Encryption)

Todos los equipos (Mac y Windows) deben tener el cifrado de disco activado en todo momento (FileVault para macOS, BitLocker para Windows).

Nuestro sistema MDM ("Kandji" o "Intune") audita esto automáticamente. Si desactivas el cifrado, tu acceso a Slack y Google Workspace será revocado instantáneamente hasta que se remedie.

2.3 Actualizaciones del Sistema Operativo (Patch Management)

Las vulnerabilidades de "Día Cero" son la principal vía de ataque.

Política de N-1: Debes estar siempre en la versión más reciente del sistema operativo o la inmediatamente anterior. Tienes un plazo de 72 horas para instalar parches de seguridad críticos una vez que IT libera la notificación.

El reinicio del equipo al menos una vez por semana es obligatorio para finalizar instalaciones de parches.

2.4 Bloqueo Automático de Pantalla

Configura tu equipo para que se bloquee automáticamente tras 5 minutos de inactividad.

Hábito: Acostúmbrate a presionar Win+L o Cmd+Ctrl+Q cada vez que te levantes de la silla, incluso si estás solo en casa. (Las mascotas también pueden borrar bases de datos caminando sobre teclados).

3. SEGURIDAD DE RED Y CONEXIONES (NETWORKING)

El aire no es seguro. Los datos en tránsito deben protegerse.

3.1 Redes Wi-Fi Públicas y "Cafeterías"

Trabajar desde cafeterías, aeropuertos o co-workings es aceptable, pero las redes abiertas son trampas mortales (Sniffing, Man-in-the-Middle).

Protocolo Obligatorio: NUNCA te conectes a sistemas internos (AWS, Dashboard de Admin, GitHub) desde una red pública sin activar primero la VPN Corporativa (NordLayer / Perimeter 81).

Preferencia: Si la red pública no pide contraseña o usa protocolos obsoletos (WEP), es preferible usar el "Hotspot" (Tethering) de tu teléfono móvil, que es una conexión cifrada y privada.

3.2 Higiene del Router Doméstico

Tu red de casa es ahora una extensión de la red corporativa.

Debes cambiar la contraseña predeterminada de administrador de tu router (la que viene en la etiqueta adhesiva).

El protocolo de seguridad de tu Wi-Fi debe ser WPA2 o WPA3. WPA/WEK están prohibidos.

Se recomienda crear una red de "Invitados" (Guest Network) en casa para tus dispositivos IoT (bombillas inteligentes, Alexa, neveras), separándolos de tu laptop de trabajo.

4. GESTIÓN DE IDENTIDAD Y ACCESOS (IAM)

Las contraseñas son el eslabón más débil.

4.1 Gestor de Contraseñas (Password Manager)

Herramienta Oficial: 1Password.

Prohibido:

Usar la misma contraseña para múltiples servicios.

Guardar contraseñas en notas adhesivas (Post-its), archivos de texto plano o en el navegador (Chrome Password Manager).

Compartir contraseñas por Slack o Email.

Uso Correcto: Genera contraseñas aleatorias de más de 20 caracteres para cada servicio y guárdalas en 1Password. Usa la función "1Password Sharing" para compartir credenciales de equipo de forma segura y temporal.

4.2 Autenticación Multifactor (MFA/2FA)

El MFA es obligatorio para el 100% de los servicios que lo soporten (Google, Slack, AWS, GitHub, Zoom).

Métodos Aceptados:

Llaves de seguridad físicas (YubiKey) - Nivel Oro.

Aplicaciones autenticadoras (Google Authenticator, Authy) - Nivel Plata.

Método Desaconsejado: SMS (vulnerable a SIM Swapping). Solo úsalo si no hay otra opción.

5. PROTECCIÓN DE DATOS Y CLASIFICACIÓN DE LA INFORMACIÓN

No todos los datos valen lo mismo. Debes saber qué estás manejando.

5.1 Niveles de Clasificación de Datos

Público: Información de marketing, web pública. (Bajo riesgo).

Interno: Políticas, wikis, organigramas. (Riesgo medio).

Confidencial: Datos de clientes (PII), código fuente, estrategias comerciales no lanzadas. (Alto riesgo).

Restringido: Claves privadas de criptografía, accesos bancarios, datos de salud de empleados. (Riesgo crítico).

5.2 Reglas de Manejo de Datos (DLP)

Descargas: Está prohibido descargar bases de datos de clientes (CSV/Excel) a tu disco duro local a menos que sea estrictamente necesario para una tarea momentánea. Deben borrarse inmediatamente después (Regla de "Tierra Quemada").

Nube No Autorizada (Shadow IT): Prohibido subir documentos de trabajo a cuentas personales de Google Drive, Dropbox o enviarlos a tu email personal para "trabajar el fin de semana".

USB/Discos Externos: El uso de memorias USB está bloqueado por defecto en todos los equipos. Si necesitas transferir datos físicos, solicita una excepción temporal a IT.

6. SEGURIDAD FÍSICA Y ENTORNO VISUAL

6.1 Política de Pantalla Limpia y Escritorio Limpio

En videollamadas, asegúrate de que no haya información sensible visible detrás de ti (pizarras con diagramas de arquitectura, contraseñas en la pared). Usa el "Blur Background" si es necesario.

Si trabajas en un espacio público, usa un Filtro de Privacidad (Privacy Screen) para evitar el "Shoulder Surfing" (gente mirando tu pantalla por encima del hombro).

6.2 Robo o Pérdida de Equipo

Es el escenario más temido, pero debemos estar preparados.

Protocolo de Reacción Rápida (SLA: 15 minutos):

Si pierdes tu equipo o te lo roban, debes notificar INMEDIATAMENTE al canal de Slack #security-incidents o al teléfono de emergencia de IT.

No tengas miedo de reportarlo. El problema no es perder el equipo (son asegurables); el problema es no avisar a tiempo para que podamos lanzar el comando de Borrado Remoto (Remote Wipe). Si reportas el robo dentro de la primera hora, no habrá repercusiones disciplinarias. Si lo ocultas por días, será causal de despido.

7. INGENIERÍA SOCIAL Y PHISHING

El hacker moderno no rompe firewalls; engaña a personas.

7.1 Verificación de Solicitudes Atípicas

CEO Fraud: Si recibes un email o WhatsApp urgente del "CEO" pidiéndote que compres tarjetas de regalo, hagas una transferencia bancaria rápida o compartas tu contraseña... ES UNA ESTAFA.

NovaTech nunca te pedirá esto por canales informales.

Verificación: Contacta a la persona por otro canal (llámala o háblale por Slack) para confirmar la identidad antes de actuar.

7.2 Enlaces y Adjuntos

Inspecciona siempre la URL antes de hacer clic. (ej. novatech-support.com NO es novatech.com).

Nunca abras adjuntos inesperados (.zip, .exe, .pdf) incluso si parecen venir de un colega. Confirma con ellos: "¿Me enviaste este archivo?".

8. SANCIONES Y CUMPLIMIENTO

La seguridad es una condición de empleo.

Las violaciones menores (ej. olvidar bloquear la pantalla repetidamente) resultarán en reentrenamiento obligatorio y amonestación verbal.

Las violaciones graves (ej. desactivar el antivirus, compartir credenciales, subir código a repositorios públicos personales) resultarán en la terminación inmediata del contrato y posibles acciones legales.

He leído, comprendido y acepto cumplir con el Protocolo de Seguridad para Trabajo Remoto de NovaTech.